

Robust Federated Learning for Credit Card Identity Fraud Detection: A Temporally-Aware Layered Defense Framework

Anonymous Authors—Design-Stage Specification

Abstract—Cross-silo federated learning (FL) enables banks to collaboratively train fraud detection models without sharing raw transaction data. However, financially motivated adversaries who compromise a client bank can poison the global model to evade detection. Existing Byzantine-robust aggregation methods—Krum, trimmed mean, Bulyan, FLTrust, and others—are stateless: each training round is evaluated independently, making them blind to temporally-adaptive attackers who alternate between malicious and benign behavior across rounds. This paper identifies the statelessness blind spot as a vulnerability of round-independent aggregators to temporally-corrupted update sequences, and presents a gated cascade defense framework comprising three complementary detection layers—norm/cosine filtering (Layer 1), spectral anomaly detection via PCA (Layer 2), and temporal sliding-window reputation scoring (Layer 3)—connected by an adaptive threshold escalation policy. We provide formal analysis of cascade error propagation under stationary benign gradient covariance, establishing a $\sim 1.6\%$ honest FPR bound, and characterize drift-affected FPR degradation via the Davis-Kahan $\sin\Theta$ theorem. A reputation forgetting mechanism with steady-state floor $R_{ss} = 0.85$ prevents permanent exclusion of honest banks after transient anomalies. A cascade-aware adaptive adversary (A6) is scoped as the operational envelope: the defense detects attacks that exceed a calibrated perturbation bound, but cannot detect adversaries who constrain updates strictly within it—a fundamental consequence of the information-theoretic gap between benign and adversarial gradient distributions. The framework is evaluated against six fraud-specific attack models across fourteen baselines and fifteen ablation configurations. This paper is the design-stage specification; experimental validation is in progress.

Index Terms—Federated learning; fraud detection; Byzantine robustness; adaptive attacks; spectral anomaly detection; temporal reputation; gated cascade.

I. INTRODUCTION

Credit card identity fraud imposes annual losses exceeding \$28 billion globally [1]. In response, financial institutions increasingly deploy machine learning models that detect fraudulent transactions in real time. A critical operational challenge is that no single bank observes enough fraud to train a high-performance model independently—fraud is rare (~ 0.1 – 3.5% of transactions) and patterns shift across merchant categories, geographic regions, and demographic segments.

Cross-silo federated learning (FL) offers a natural solution: 10–100 banks jointly train a shared fraud detection model without exchanging raw transaction data [2], [3]. In each round, the aggregation server distributes the current global model to participating banks; each bank trains locally on its private transaction data and sends back a model update;

the server aggregates these updates via Federated Averaging (FedAvg) [4] or a robust variant.

A. The Fraud-Specific Poisoning Threat

This collaborative architecture introduces a critical vulnerability: a malicious bank—or a legitimate bank compromised by a fraud ring—can submit crafted updates that poison the global model. Critically, the attacker’s objective is *not* to degrade overall model accuracy (which would be trivially detected). Rather, the attacker aims for **targeted evasion**: causing the model to misclassify specific fraud patterns as legitimate while maintaining overall utility to avoid suspicion. This is an incentive-driven, accuracy-preserving poisoning attack fundamentally different from the random or untargeted Byzantine faults studied in the robust FL literature [5]–[7].

Fraud rings operate in campaigns: they probe defenses, adapt when detected, and re-emerge with modified tactics. This temporally-adaptive behavior makes per-round defenses inadequate.

B. The Statelessness Blind Spot

Existing Byzantine-robust aggregation methods—Krum [8], Coordinate-wise Median [9], Trimmed Mean [9], Bulyan [10], FLTrust [11], FoolsGold [12], FLDetector [13]—share a critical blind spot: they are **stateless**. Each training round is evaluated independently. A malicious client that behaves honestly for three rounds, performs a targeted attack on the fourth, and pauses on the fifth—will evade any per-round defense.

Formally, let $f_t \in \{0, 1\}$ indicate whether the defense rejects the attacker’s update at round t . A stateless defense produces an independent (or Markov-1) sequence $\{f_t\}$: the attacker can probe thresholds by observing f_t directly across rounds. A stateful defense with memory k maintains a detection statistic $S_t = \sum_{i=t-k+1}^t w_i f_i$, where w_i are temporal weights. To succeed at round t , the attacker must have been accepted in $\geq \tau$ of the last k rounds—forcing extended honest behavior that raises the cost of attack.

C. Contributions

This paper presents a **gated cascade defense framework** for cross-silo FL fraud detection with three complementary contributions:

- 1) **Detection primitive.** We identify and formalize the *statelessness blind spot*—the vulnerability of round-independent robust aggregators to temporally-corrupted update sequences. We show that any stateless aggregation rule (Krum, Median, Trimmed Mean) can be bypassed by a sustained sequence of bounded-perturbation updates, even if each individual update passes per-round checks. The grinding attack formalization captures this alternating behavior.
- 2) **Stateful cascade design.** A three-layer gated cascade with complementary detection principles: norm/cosine filtering for rapid trivial-attack rejection, spectral anomaly detection for coordinated multi-client attacks, and temporal sliding-window reputation scoring for slow adaptive poisoning. We prove FPR bounds under stationary benign gradient covariance (Stewart’s theorem, $\sim 1.6\%$ honest FPR) and characterize drift-affected FPR degradation via the Davis-Kahan $\sin\Theta$ theorem. A fixed-point analysis establishes convergence neighborhoods for the adaptive threshold dynamics, and a reputation steady-state floor $R_{SS} = 0.85$ provides a fairness guarantee. The cascade-aware adaptive adversary (A6) is scoped as the **operational envelope** (Contribution 3), not a failure case.
- 3) **Attack taxonomy and operational envelope.** We contribute six fraud-specific attack models (A1–A6) spanning the adversarial capability spectrum. For the cascade-aware adaptive adversary (A6), we define an explicit operational envelope: the cascade guarantees detection of any adversary whose update sequence exceeds the per-layer calibrated bounds, but cannot detect adversaries who constrain perturbations strictly within those bounds—a fundamental consequence of the information-theoretic gap between benign and adversarial gradient distributions. This framing transforms the known limitation into an honest foundational claim.

This paper presents the design-stage specification. Experimental validation is in progress on cloud infrastructure.

D. Roadmap

Section II reviews related work. Section III formalizes the threat model. Section IV describes the proposed framework. Section V specifies the attack models. Section VI presents the experimental design and expected results. Section VII provides formal analysis. Section VIII addresses regulatory and ethical considerations. Section IX discusses limitations. Section X concludes.

II. RELATED WORK

A. Federated Learning for Fraud Detection

A small but growing body of work applies FL to credit card fraud detection. Yang *et al.* [2] first proposed FL for cross-institution fraud detection using FedAvg on the European Credit Card (ECC) dataset, demonstrating feasibility but evaluating only IID splits with no poisoning scenario.

Abdul Salam *et al.* [14] addressed data imbalance in FL fraud detection using SMOTE-based augmentation, but did not consider adversarial clients. Zheng *et al.* [15] evaluated FL fraud detection on the IEEE-CIS dataset with geographic non-IID splits, reporting that FedAvg maintains $\sim 85\%$ AUC under mild skew.

Naresh

textitet al.

citenaresht2024 surveyed FL architectures for payment fraud and identified adversarial robustness as an open challenge. Farrukh

textitet al.

citefarrukht2025 provided the most comprehensive survey, concluding that “no existing study evaluates robust aggregation or poisoning defenses in the fraud detection context.”

Refined gap: While robust aggregation methods have been evaluated on financial FL tasks (FedML Financial, IEEE-CIS benchmarks), **no existing study evaluates their vulnerability to temporally-adaptive adversaries under the operational constraints of a regulated financial consortium:** (i) non-stationary concept drift from fraud evolution, (ii) multi-round attack scheduling across retraining cycles, (iii) regulatory requirements for auditability and explainability that preclude black-box aggregation, and (iv) the specific incentive structure of a small-N consortium (10 institutions) where membership is known and exclusion is costly. The contribution is an *evaluation gap*, not a literature void.

B. Byzantine-Robust Aggregation

The Byzantine-robust FL literature provides families of aggregation methods to bound the influence of malicious updates. Krum [8] selects the update closest to $N - m - 2$ others, with proven convergence under majority honesty. Coordinate-wise median and trimmed mean [9] provide element-wise robustness. Bulyan [10] combines selection with coordinate-wise trimming. FLTrust [11] uses a server-held clean dataset as an absolute reference. FoolsGold [12] detects collusive poisoning via pairwise similarity. FLDetector [13] predicts expected updates from historical trajectories and flags deviations.

Limitation for fraud FL: These methods share three weaknesses. First, they are *stateless*—each round evaluated independently, enabling grinding attacks (§V-B). Second, they assume malicious updates are statistically distinguishable from honest ones in a single round, but non-IID banking data produces a broad honest cluster masking targeted evasion. Third, methods inspecting per-client gradients (FLTrust, FoolsGold, FLDetector) are incompatible with Secure Aggregation.

Recent temporally-aware defenses—FLAME [18], ShieldFL [19], FedDef [20]—improve on stateless aggregation but were evaluated on image classification with random label-flipping, not tabular fraud data with incentive-driven targeted evasion.

C. Adaptive Adversarial Attacks

The adversarial ML community has studied adaptive attackers extensively. Fang *et al.* [21] showed gradient-

TABLE I
LITERATURE GAP ANALYSIS.

Literature	Poisoning	Temporal	Fraud	Non-IID
FL fraud detection [2], [14]–[17]	×	×	✓	Partial
Byzantine-robust [8]–[13]	✓	×	×	×
Adaptive attacks [21]–[25]	✓	Partial	×	×
This paper	✓	✓	✓	✓

matching attacks evade Krum and trimmed mean in IID settings. Jagielski *et al.* [22] demonstrated omniscient attackers craft minimally-perturbed updates passing detection. Shejwalkar and Houmansadr [23] proposed manipulated FedAvg combining gradient manipulation with strategic participation. Baruch *et al.* [24] introduced “fall of empires” attacks exploiting non-IID outlier gradients. Xie *et al.* [25] studied dynamic backdoor triggers changing each round to evade static defenses.

Our position: These works establish that adaptive attackers exist and are effective against per-round defenses. Our contribution is the observation that *fraud-specific incentives create a natural temporally-adaptive attack pattern* that existing FL fraud detection work has not addressed, combined with a defense framework designed specifically for this domain.

D. Gap Synthesis

III. THREAT MODEL

A. System Model

We consider a cross-silo FL consortium with N banks. Bank i holds a private dataset $\mathcal{D}_i$ drawn from a non-IID distribution $\mathcal{P}_i(X, y)$ reflecting its customer demographics, geographic region, and fraud environment. A centralized aggregation server coordinates R rounds of training.

Protocol. In each round t : (1) Server distributes global model $\theta^{(t)}$ to all banks; (2) each bank trains for E epochs, producing update $g_i^{(t)}$; (3) banks send $\{g_i^{(t)}\}$ to the server; (4) server applies the defense framework and computes $\theta^{(t+1)}$; (5) repeat for R rounds.

Assumptions. N is small (10–100) and stable. Banks are regulated financial institutions. The server does **not** observe raw transaction data—only gradient updates.

B. Adversarial Objectives

The adversary controls m malicious clients ($m \ll N$). The objective is **targeted model degradation**: to cause the global model to misclassify specific fraud patterns as legitimate while maintaining overall utility.

Formally, the adversary has target set $\mathcal{T}$ of transactions to evade detection on. Let $\mathcal{L}_{\text{acc}}(\theta)$ be accuracy on non-target transactions, and $\mathcal{L}_{\mathcal{T}}(\theta)$ be the false negative rate on target transactions:

$$\text{maximize } \mathcal{L}_{\mathcal{T}}(\theta) \quad \text{subject to } \mathcal{L}_{\text{acc}}(\theta) \geq \eta \quad (1)$$

where η is a utility threshold (e.g., 95% of clean model accuracy). This distinguishes targeted evasion from untargeted Byzantine faults.

C. Adversarial Capabilities (Kerckhoffs’s Principle)

The adversary:

- **Controls** m client banks and can dynamically register/dispose of Sybil identities under resource constraints (cost per identity γ_{syb}), reflecting realistic botnet-enabled fraud rings.
- **Knows** the defense architecture, aggregation rules, threshold functions, and current global model.
- **Observes** the model’s behavior on probe transactions (realistic in fraud—attackers can submit probes).
- **Cannot** compromise the aggregation server or other clients.

Trust boundary. The trusted consortium server assumption is standard in the Byzantine-robust literature [8]–[13] and grounded in cross-silo banking practice: consortia operate under joint governance agreements with audited access controls (Visa B2B Connect, Fnality). Server compromise is discussed as a limitation in §IX.

D. Why Stateless Defenses Fail

Consider a temporally-adaptive grinding attack: Round 1—malicious update $g_{\text{adv}}^{(1)}$ (detected and rejected). Round 2—honest update (accepted). Rounds 3–4—honest. Round 5—modified malicious update $g_{\text{adv}}^{(5)}$. The stateless defense evaluates each round independently, providing no mechanism to cumulatively penalize the attacker’s pattern.

Formal intuition. Let $f_t \in \{0, 1\}$ indicate detection. A stateless defense produces $\mathbb{E}[f_t \mid \theta^{(t)}, g_{\text{adv}}^{(t)}] = h(g_{\text{adv}}^{(t)})$. The attacker adapts $g_{\text{adv}}^{(t)}$ in response to $\theta^{(t)}$, treating the defense as a bandit with re-draw each round. A stateful defense with memory k maintains $S_t = \sum_{i=t-k+1}^t w_i f_i$, forcing sustained honest behavior across the memory window.

E. Assumptions and Scope

The following are **out of scope** for the current design: aggregation server compromise (standard assumption; TEE-based mitigation as future work); regulatory capture arbitrage (separate AML compliance mechanism); synthetic identity injection (data-level attack orthogonal to model-level defense); and reputation identity cycling (consortium membership management is operational).

IV. PROPOSED FRAMEWORK: GATED CASCADE DEFENSE

A. Architecture Overview

The framework is a **gated cascade** of three detection layers, each specializing in a distinct threat class. An adaptive threshold escalation policy routes each update to the appropriate layer based on confidence, bounding computational cost.

Design principle: division of labor. No single layer must detect all attack types. Layer 1 catches trivial attacks efficiently. Layer 2 catches coordinated multi-client attacks via spectral separation. Layer 3 catches slow adaptive poisoning via temporal memory. The ensemble covers the threat space through complementary detection principles.

Gating, not fusion. Unlike ensemble methods combining multiple outputs, the cascade is a gate: each update is handled by exactly one layer based on the escalation policy (§IV-E). If Layer 1 is confident an update is benign, it is accepted directly. If uncertain, it escalates to Layer 2, and so on. This avoids the selection-bias problem of fusing signals from layers operating on different data subsets.

Privacy-aware pipeline. To preserve gradient confidentiality, each client applies local DP noise (ϵ_{local}) to their gradient before the update enters the detection cascade (Layer 2 and Layer 3 operate on DP-noised gradients). L2 and L3 execute inside a Trusted Execution Environment (Intel SGX / AMD SEV / TDX) that protects the aggregation logic, DP accounting, and reputation state; only anomaly scores and reputation weights leave the trusted boundary. Layer 1’s norm check operates outside the enclave (gradient norms reveal no transaction-level information and are DP-noised before arrival). Remote attestation (Intel DCAP / AMD SEV-SNP) lets each consortium member verify the enclave’s identity and code integrity before submitting updates. The trust model and attestation design are detailed in §VII-D.

B. Layer 1: Norm and Cosine Filtering

Purpose. Rapidly reject trivially malicious updates—extreme magnitude or opposing direction—before more expensive layers process them.

Mechanism. For each $g_i^{(t)}$:

$$s_1(g_i^{(t)}) = \frac{\|g_i^{(t)}\|_2}{\max_j \|g_j^{(t)}\|_2} \quad (2)$$

$$s_2(g_i^{(t)}) = \cos(g_i^{(t)}, \mu^{(t)}) \quad \text{where } \mu^{(t)} = \frac{1}{N} \sum_j g_j^{(t)} \quad (3)$$

An update is flagged if $\|g_i\|_2 > \tau_{\text{norm}}$ OR $\cos(g_i, \mu) < \tau_{\text{cos}}$.

Confidence c_1 . High when L2 norm separation is large: $c_1 = \max(0, (\|g_i\|_2 - \tau_{\text{norm}})/(\max_{\text{norm}} - \tau_{\text{norm}}))$ for flagged updates, or $c_1 = \max(0, (\tau_{\text{norm}} - \|g_i\|_2)/\tau_{\text{norm}})$ for accepted updates.

Thresholds. $\tau_{\text{norm}} = 1.5\sigma_{\text{max}}$ (1.5 standard deviations above mean norm in clean round). $\tau_{\text{cos}} = 0.5$.

Confidence-calibrated rejection. The cascade rejects at L1 only when confidence $c_1 < \theta_{\text{low}}$. For honest updates ($\|g_i\| \leq \tau_{\text{norm}}$), $c_1 = (\tau_{\text{norm}} - \|g_i\|)/\tau_{\text{norm}}$, so $c_1 < \theta_{\text{low}}$ occurs when $\|g_i\| > \tau_{\text{norm}} \cdot (1 - \theta_{\text{low}})$. Setting $\theta_{\text{low}} = 0.21$ gives $\|g_i\| > 0.79\tau_{\text{norm}}$, which for $\tau_{\text{norm}} = \mu + 1.5\sigma_{\text{norm}}$ yields $\text{FPR}_1 \leq 0.003$ under the $\chi(d)$ norm model (tail probability of $\|g_i\|$ exceeding $\mu + 1.5\sigma_{\text{norm}} \cdot 0.79$). This is the confident-rejection rate, distinct from the L1 flagging rate (~ 0.067 at $\tau_{\text{norm}} = 1.5\sigma$). The θ_{low} value is a design choice: a lower value reduces L1 FPR but increases the fraction requiring L2 escalation.

C. Layer 2: Spectral Anomaly Detection via PCA

Purpose. Detect **coordinated multi-client attacks**— $m \geq 3$ colluding clients sending correlated updates that evade per-client filtering but share a detectable spectral signature.

Mechanism. Let $G^{(t)} \in \mathbb{R}^{N \times d}$ be the client update matrix. Apply PCA to the residual $R^{(t)} = G^{(t)} - \mathbf{1}_N \otimes$

$\mu^{(t)}$. Reconstruction error for client i in the top- k principal subspace:

$$e_i^{(t)} = \|r_i - r_i U_k U_k^T\|_2 \quad (4)$$

where U_k contains the top- k components ($k = 3$). Clients with high reconstruction error—updates outside the dominant correlation structure—are flagged.

Sliding-window PCA for concept drift. Covariance Σ_t of benign gradients evolves with fraud patterns. Rather than a fixed reference, the PCA subspace $U_k^{(t)}$ is recomputed on a rolling window of length P rounds. The drift between recomputations is bounded by the corrected Davis-Kahan $\sin \Theta$ bound (§VII-A), relating the FPR degradation to $\epsilon_{\text{drift}}/\text{gap}$.

Why this works for collusive fraud. Under honest behavior, each bank’s update reflects its independent transaction distribution. While distributions differ across banks, updates are not systematically correlated. Under m colluding attackers sending correlated updates (e.g., all minimizing loss on fraudulent transactions from the same merchant category), the malicious updates occupy a shared subspace. For $m \geq 3$, this component becomes detectable in the residual of the $k = 3$ subspace.

Confidence c_2 . Proportional to separation between flagged and unflagged residual distributions: $c_2 = (\mu_{\text{flagged}} - \mu_{\text{unflagged}})/(\sigma_{\text{flagged}} + \sigma_{\text{unflagged}})$.

D. Layer 3: Temporal Reputation Scoring

Purpose. Detect **slow, adaptive poisoning** (the grinding attack) that L1 and L2 miss—small, bounded perturbations per round that accumulate over time.

Mechanism. Each client maintains a sliding-window reputation score $R_i^{(t)} \in [0, 1]$ over the most recent W rounds. The reputation is the mean anomaly score over the window:

$$R_i^{(t)} = \frac{1}{W} \sum_{s=t-W+1}^t a_i^{(s)} \quad (5)$$

where $a_i^{(s)} \in [0, 1]$ is the per-round anomaly score and $W = 50$ is the window length. Unlike an exponentially weighted moving average (EMA), the sliding window imposes a hard memory bound: anomalous behavior persists for exactly W rounds and is fully expunged after.

Clients are flagged by **deviation from their own baseline**, not via a global threshold:

- 1) **Continuously-evolving baseline.** Rather than a one-shot warm-up computation, each client’s baseline evolves via EWMA:

$$\begin{aligned} \bar{R}_i^{(t+1)} &= \lambda \cdot \bar{R}_i^{(t)} + (1 - \lambda) \cdot R_i^{(t+1)}, \\ \sigma_{R,i}^{(t+1)} &= \sqrt{\lambda \cdot [\sigma_{R,i}^{(t)}]^2 + (1 - \lambda) \cdot (R_i^{(t+1)} - \bar{R}_i^{(t+1)})^2} \end{aligned} \quad (6)$$

with decay factor $\lambda = 1 - 1/W_h = 0.995$ (equivalent memory of $W_h = 200$ rounds). Initial values: $\bar{R}_i^{(0)} = 0.50$, $\sigma_{R,i}^{(0)} = 0.10$.

- 2) **Detection:** Client i is flagged when $R_i^{(t)} < \bar{R}_i^{(t)} - \tau_\Delta \cdot \sigma_{R,i}^{(t)}$, with margin $\tau_\Delta = 5$ —a 5σ deviation from evolving baseline.
- 3) **Adversarial inflation bounded.** An attacker present from round 1 must maintain consistent deviation across *all* rounds to inflate $\bar{R}_i$, not just a fixed warm-up window. The EWMA’s infinite impulse response decays past contributions exponentially (λ^t), so a transient inflation spike at round 1 decays to λ^t of its original value by round t . After $W_h = 200$ rounds, the residual from an initial inflation δ_0 is $\lambda^{W_h} \cdot \delta_0 \approx 0.37\delta_0$ —about 63% of the initial spike is retained at the 1-year mark. This is a residual gap: a consistent long-term attacker can bias their baseline, though the bias converges to a steady state δ_∞ bounded by the attacker’s sustainable deviation.

The per-client baseline is essential in non-IID FL: honest gradient bias Δ_i (from domain-specific transaction distributions) produces persistent reputation offsets that a global threshold τ_R would misclassify as malicious. Empirical measurement on a Dirichlet $\alpha = 0.5$ non-IID split shows honest per-client $\sigma_{R,i} \approx 0.015$ with $|\Delta R_i^{(t)}| \leq 0.013$ —a 5σ margin ($\tau_\Delta = 5$) avoids false positives while detecting a > 0.075 deviation (the attack signal).

The anomaly score $a_i^{(t)}$ combines three signals with fixed weights:

$$a_i^{(t)} = 0.4 \cdot d_{\text{grad}}^{(t)} + 0.4 \cdot \ell_{\text{val}}^{(t)} + 0.2 \cdot s_{\text{probe}}^{(t)} \quad (7)$$

where $d_{\text{grad}}^{(t)}$ is the cosine distance from the client’s gradient to the peer mean, $\ell_{\text{val}}^{(t)}$ is the local validation loss (bounded to $[0, 1]$ via min-max normalization over the client history), and $s_{\text{probe}}^{(t)}$ is the agreement score on a shared probe set.

Reputation forgetting mechanism. To prevent permanent exclusion of honest banks after transient anomalies:

- **Sliding window:** $W = 50$ rounds. Anomalous updates affect reputation for at most W rounds.
- **Steady-state floor:** $R_{\text{SS}} = 0.85$ —reputation cannot fall below this floor for non-flagged clients.
- **Hard reset on violation:** If a client is flagged for $F_{\text{max}} = 3$ consecutive rounds, their window is set to the anomaly score of the current round only, purging accumulated borderline behavior.
- **Per-client adaptive threshold:** The flagging threshold is $T_i^{(t)} = \bar{R}_i^{(t)} - \tau_\Delta \cdot \sigma_{R,i}^{(t)}$ (§IV-D), evolving via EWMA (Eq. 6). This replaces the fixed global threshold τ_R used in earlier versions of this design—critical for non-IID settings where honest client reputations have persistent offsets.

Probation for all new clients. Every client entering the consortium (whether new or re-joining after inactivity) enters $P = 10$ probation rounds at 50% aggregation weight, regardless of their reputation score. This prevents identity cycling: an adversary cannot gain full-weight influence by simply registering a fresh identity. After probation, weight is restored proportionally to reputation.

Cold-start. New clients enter with $R_i^{(0)} = 0.50$, subject to increased scrutiny during a $t_0 = 10$ -round bootstrap, with

Algorithm 1 Gated cascade escalation policy.

```

1: for each update  $g_i^{(t)}$  do
2:   Compute  $c_1(g_i^{(t)})$  via Layer 1
3:   if  $c_1 > \theta_{\text{high}}$  then
4:     accept( $g_i^{(t)}$ )
5:   else if  $c_1 < \theta_{\text{low}}$  then
6:     reject( $g_i^{(t)}$ )
7:   else
8:     Escalate to Layer 2; compute  $c_2(g_i^{(t)})$ 
9:     if  $c_2 > \theta_{\text{high}}$  then
10:      accept( $g_i^{(t)}$ )
11:     else if  $c_2 < \theta_{\text{low}}$  then
12:      reject( $g_i^{(t)}$ )
13:     else
14:       Escalate to Layer 3; compute  $c_3(g_i^{(t)})$ 
15:       if  $c_3 > \theta_{\text{high}}$  then
16:        accept( $g_i^{(t)}$ )
17:       else
18:        reject( $g_i^{(t)}$ )
19:       end if
20:     end if
21:   end if
22: end for

```

reputation linearly ramping to $R_{\text{SS}} = 0.85$ over the bootstrap period. During bootstrap, $c_3 = R_i \cdot c_{3,\text{base}} \cdot (t/t_0)$.

Confidence c_3 . $c_3 = R_i^{(t)} \cdot (1 - \exp(-2t/t_0))$, proportional to both reputation and tenure.

E. Adaptive Threshold Escalation Policy

Threshold adaptation. The bounds $\theta_{\text{high}}, \theta_{\text{low}}$ are dynamic based on estimated attack rate $\rho^{(t)}$:

$$\theta_{\text{high}}^{(t+1)} = \theta_{\text{high}}^{(t)} - \eta_{\text{attack}}(\rho^{(t)} - \rho_0) \cdot \mathbf{1}_{\rho^{(t)} > \rho_0} \quad (8)$$

$$\theta_{\text{low}}^{(t+1)} = \theta_{\text{low}}^{(t)} + \eta_{\text{attack}}(\rho^{(t)} - \rho_0) \cdot \mathbf{1}_{\rho^{(t)} > \rho_0} \quad (9)$$

$$\theta_{\text{high}}^{(t+1)} = \theta_{\text{high}}^{(t)} + \eta_{\text{relax}}(\rho_0 - \rho^{(t)}) \cdot \mathbf{1}_{\rho^{(t)} < \rho_0} \quad (10)$$

$$\theta_{\text{low}}^{(t+1)} = \theta_{\text{low}}^{(t)} - \eta_{\text{relax}}(\rho_0 - \rho^{(t)}) \cdot \mathbf{1}_{\rho^{(t)} < \rho_0} \quad (11)$$

with $\eta_{\text{attack}} = 0.15$, $\eta_{\text{relax}} = 0.05$, $\rho_0 = 0.1$.

F. Reputation-Weighted Adaptive Aggregation

The final aggregation weights client updates by reputation:

$$\theta_{\text{agg}}^{(t+1)} = \theta^{(t)} - \alpha \cdot \frac{\sum_i w_i g_i^{(t)}}{\sum_i w_i} \quad (12)$$

where $w_i = R_i^{(t)}$ if $R_i^{(t)} > T_i$ (per-client detection threshold from §IV-D), else $w_i = \varepsilon R_i^{(t)}$ ($\varepsilon \ll 1$).

G. Client Contribution Scoring (Shapley)

To incentivize high-quality contributions beyond mere reputation maintenance, every $P = 50$ rounds (matching the PCA recomputation cadence), each client’s marginal

TABLE II
DUAL-THRESHOLD ARCHITECTURE FOR PER-CLIENT DETECTION.

Threshold	Symbol	Formula and Purpose
Reputation (R_i)	$T_i^{(t)}$	$T_i^{(t)} = \bar{R}_i^{(t)} - \tau_\Delta \cdot \sigma_{R,i}^{(t)}$; flags when EMA reputation $R_i^{(t)}$ drops below threshold. $\sigma_{R,i}^{(t)}$ evolves via EWMA (Eq. 6). Baseline $\tau_\Delta = 5$, initial $\sigma_{R,i}^{(0)} \approx 0.015$
RCC deviation (ΔRCC)	$\tau_{\Delta,i}$	$\tau_{\Delta,i} = RCC_i^{(base)} + k \cdot \sigma_{\ r\ ,i} / \sqrt{W}$; flags when short-window RCC deviates from baseline. $\sigma_{\ r\ ,i} = \text{std}(\ r_i^{(s)}\)$, per-round residual-norm std ($k = 3$)

contribution to fraud detection performance is computed via Truncated Monte Carlo Shapley:

$$\hat{\phi}_i = \frac{1}{K} \sum_{k=1}^K [F(S_{\pi_k}^{<i} \cup \{i\}) - F(S_{\pi_k}^{<i})] \quad (13)$$

H. Per-Client Baseline Measurement Protocol

The per-client detection threshold $T_i^{(t)} = \bar{R}_i^{(t)} - \tau_\Delta \cdot \sigma_{R,i}^{(t)}$ (Eq. 6) is the key innovation replacing the global threshold τ_R , and its EWMA evolution is now specified above.

1) *Dual-Threshold Architecture*: Two distinct per-client thresholds serve complementary purposes with separate statistics:

Both thresholds are initially calibrated during W_h warm-up rounds and then evolve via EWMA (Eq. 6). They use distinct statistics ($\sigma_{R,i}$ vs. $\sigma_{\|r\|,i}$) and should never be conflated.

2) *Initial Baseline Calibration* ($W_h = 200$ Rounds): During an initial trusted calibration period (inside the TEE, §VII-D), each client participates in standard FedAvg with all-reduce averaging. For each client i and round $s = 1 \dots W_h$, record:

$g_i^{(s)}$ — client's gradient update

$\mu^{(s)} = \frac{1}{N} \sum_j g_j^{(s)}$ — peer mean

$r_i^{(s)} = g_i^{(s)} - \mu^{(s)}$ — residual

$R_i^{(s)}$ — client i 's reputation score at round s

3) *Initial Baseline Estimation*: Compute per-client reference statistics to initialize the EWMA (Eq. 6):

$$\bar{R}_i^{(0)} = \frac{1}{W_h} \sum_s R_i^{(s)} \quad (14)$$

$$\sigma_{R,i}^{(0)} = \text{std}(\{R_i^{(s)}\}_{s=1}^{W_h}) \quad (15)$$

$$RCC_i^{(base)} = \left\| \frac{1}{W_h} \sum_s r_i^{(s)} \right\|_2 / \left(\frac{1}{W_h} \sum_s \|r_i^{(s)}\|_2 \right) \quad (16)$$

$$\sigma_{\|r\|,i} = \text{std}(\{\|r_i^{(s)}\|_2\}_{s=1}^{W_h}) \quad (17)$$

After initialization, $\bar{R}_i^{(t)}$ and $\sigma_{R,i}^{(t)}$ evolve via EWMA (Eq. 6) while $RCC_i^{(base)}$ and $\sigma_{\|r\|,i}$ remain static until drift-triggered recalibration (§VI-C). The RCC baseline is static because the RCC ratio is less sensitive to mild concept drift (the numerator and denominator both drift in the same direction), but a hard

reset is available if $RCC_i^{(t)}$ deviates $\geq 3\sigma$ from the initial baseline.

4) Disclosures:

- 1) The reported $\sigma_{R,i} \approx 0.015$ was measured on the windowed reputation score R_i in a single toy logistic regression simulation ($d = 100$, $N = 10$, Dirichlet $\alpha = 0.5$). This is a preliminary observation, not a design principle.
- 2) $\sigma_{\|r\|,i}$ was not reported in the original simulation—it is an open parameter that must be measured empirically. Its value depends on gradient dimensionality d and SGD batch size in ways $\sigma_{R,i}$ does not.
- 3) The Dirichlet $\alpha = 0.5$ observation for $RCC_i^{(base)}$ is also a single-simulation datapoint. The α sweep (§VI-D) will establish whether the per-client baseline approach generalizes.

5) Threshold Selection:

$$T_i = \bar{R}_i - \tau_\Delta \cdot \sigma_{R,i} \quad (\tau_\Delta = 5) \quad (18)$$

$$\tau_{\Delta,i} = RCC_i^{(base)} + k \cdot \sigma_{\|r\|,i} / \sqrt{W} \quad (k = 3) \quad (19)$$

where $k = 3$ approximates a 3σ bound on RCC fluctuations under stationary Σ . The Dirichlet α sweep ($\alpha \in \{0.1, 0.3, 0.5, 1.0, 5.0\}$) will test how both thresholds vary with non-IID degree. Note: the $1/\sqrt{W}$ correction applies only to $\tau_{\Delta,i}$ because it uses a per-round std ($\sigma_{\|r\|,i}$) to bound a windowed statistic (RCC_i). The T_i formula involves $\sigma_{R,i}$, which is already on the windowed reputation scale, so no $1/\sqrt{W}$ correction is needed.

6) *Circular Bootstrap Resolution*: The warm-up phase vulnerability (no defense during W_h rounds) is addressed via three safeguards:

- 1) **Trusted execution**: Calibration runs inside a TEE with code signed by the consortium's independent auditor. All W_h rounds are attested and logged.
- 2) **Robust estimator**: If TEE trust is unavailable, use the geometric median of residuals as a robust baseline estimate: $r_{GM} = \text{argmin}_r \sum_i \sum_s \|r_i^{(s)} - r\|_2$. This tolerates up to 50% corrupted rounds.
- 3) **Blinding**: During W_h , each client's gradient is individually noise-masked: $g'_i = g_i + \eta_i$, $\eta_i \sim \mathcal{N}(0, \sigma_{\text{blind}}^2)$. The noise is removed inside the TEE after baseline computation, preventing an adversary from identifying the warm-up period.

These safeguards reduce but do not eliminate the bootstrap vulnerability. The EWMA baseline (Eq. 6) further bounds the impact: even if the initial baseline is compromised, the attacker must sustain consistent deviation across *all* rounds to maintain an inflated threshold, and past inflation decays exponentially at rate λ^t . The initial $W_h = 200$ rounds remain a bootstrap dependency—fully eliminating this is an open problem.

where $K = 100$ random permutations, $S_{\pi_k}^{<i}$ is the set of clients preceding i in permutation π_k , and F measures fraud-F1 on a held-out validation set. For $N = 10$ clients, this requires $K \cdot N = 1,000$ forward passes every $P = 50$ rounds—20 evaluations per round, negligible for the target infrastructure.

TABLE III
ATTACK MODEL TAXONOMY.

ID	Attack	Primary Layer	Expected ASR (UB)
A1	Naive Model Replacement	L1 (Norm)	≤ 0.10
A2	Gradient Grinding	L3 (Reputation)	≤ 0.35
A3	Spectral-Matching Collusion	L2 (Spectral)	≤ 0.30
A4'	Insider Collusion	L2 (Spectral)	≤ 0.40
A4''	Aggregator Compromise	Fallback	≤ 0.50
A5	Data Feature Poisoning	Data + L3	≤ 0.40

The Shapley values complement the reputation score: ϕ_i measures the *empirical marginal contribution* of client i 's data to model quality, while $R_i^{(t)}$ measures *behavioral trustworthiness*. A client with high reputation but low Shapley value may be providing low-quality data honestly—a flag for data quality review rather than malicious exclusion.

V. ATTACK MODELS

A. Attack Taxonomy

Five fraud-specific attack models are defined (Table III).

B. Gradient Grinding (A2)

The grinding attack uses a 4-phase schedule:

Phase 1: **Honest updates and build reputation.**

Phase 2: **Subliminal rounds** ($\approx 20 \times 59$): $(t - 20)/40$. The ramp ensures no single round triggers L1 or L2.

Phase 3: **Active, normal** ($\approx 60 \times 99$):

Phase 4: **Good updates and rebuild reputation.**

Parameters. $\lambda_{\max} = 0.15$: individual updates remain within 1.5σ of honest mean.

C. Spectral-Matching Collusion (A3)

$M \geq 3$ malicious clients share a collusion perturbation: $g_{\text{adv},j}^{(t)} = g_{\text{honest},j}^{(t)} + \eta_j^{(t)}$, where $\eta_j^{(t)} \sim \mathcal{N}(\mu_{\text{collude}}, \Sigma_{\text{collude}})$. Per-attacker scaling $s_j \sim \text{Uniform}[0.8, 1.2]$ avoids exact equality.

D. Insider Collusion (A4')

$m \leq \lfloor N/3 \rfloor$ legitimate consortium members, each subject to KYC/regulatory onboarding, coordinate to poison the global model. Unlike A3 (arbitrary colluding adversaries), insiders hold valid credentials and can submit seemingly plausible updates. Detection relies on L2 spectral analysis of correlated residuals across the m insiders.

Rational standard. $\leq \lfloor N/3 \rfloor$ aggregation bounds require $< N/2$ Byzantine clients for statistical guarantees; in practice, a consortium of 10 banks with ≥ 4 colluding members is unlikely under regulatory oversight.

Projected ASR (UB): ≤ 0.40 . The attack is harder than A3 because insiders can better mimic benign gradient distributions, but the spectral correlation signature persists.

E. Aggregator Compromise (A4'')

An external adversary compromises the aggregation server, gaining access to raw gradients and the ability to tamper with aggregation. The TEE architecture (§VII-D) limits this: the attacker can deny service or observe enclave outputs but cannot inspect enclave memory. The fallback mechanism reverts to standard FedAvg under dispute.

Projected ASR (UB): ≤ 0.50 (reflects service-disruption ceiling, not model poisoning).

F. Data Feature Poisoning (A5)

The attacker controls the input data quality of a compromised client, injecting corrupted transactions during training rather than crafting poisoned gradients. Distinguished from A2 by targeting the data pipeline rather than the model update: $x_{\text{poison},j}^{(t)} = (1 - \delta_j)x_{\text{clean}} + \delta_j\eta_{\text{poison}}$. Detection via L3 reputation scoring over time, as per-query feature anomalies accumulate across rounds.

Projected ASR (UB): ≤ 0.40 . Slower than A2 because reputation degrades gradually, but harder to attribute to any single round.

G. Cascade-Aware Adaptive Attack (A6)

The most sophisticated threat model: an adversary aware of the full cascade topology, thresholds (including the per-client detection threshold T_i), and sliding-window mechanism. The adversary adapts their attack strategy in response to the defense state $(\theta_{\text{high}}^{(t)}, \theta_{\text{low}}^{(t)}, \{R_i^{(t)}\})$ observed via probe transactions. Two adaptive strategies are modeled:

Threshold publisher: sends gradients of gradually increasing magnitude to estimate $\theta_{\text{high}}^{(t)}$ and $\theta_{\text{low}}^{(t)}$, then crafts updates that land in the acceptance region.

Reputation attacker: maintains $R_i^{(t)} > T_i$ by interspersing honest updates with carefully bounded malicious ones, exploiting the $W = 50$ sliding window's delay.

Operational envelope. The cascade guarantees detection of any adversary whose update sequence violates at least one of the following conditions over any sliding window of length W :

- **L1 envelope:** $\|g_i\|_2 > \tau_{\text{norm}}$ (magnitude bound) — per-round to per-round, constant scale.
- **L1 envelope:** $\cos(g_i, \mu) < \tau_{\text{cos}}$ (directional bound) — per-round to per-round, constant scale.
- **L2 envelope:** PCA reconstruction error $e_i > \tau_2$ (spectral bound) — per-round to per-round, constant scale.
- **L3 envelope:** $R_i < T_i$ (reputation below per-client threshold) — windowed reputation R_i to windowed threshold T_i , same RCC-normalized scale.

An adversary who constrains their updates to stay strictly within *all four envelopes simultaneously* can operate indefinitely. This is not a design flaw—it is a fundamental consequence of the information-theoretic gap between benign and adversarial gradient distributions: no gradient-based

detector can distinguish attack from drift when the adversary’s updates lie within the typical set of the benign distribution (see §V-H). The cascade is an **early-warning alarm for high-magnitude or structurally anomalous updates**, not a general adversary-proof aggregator.

Projected ASR: 0.50 (definitive validation requires experimental implementation with adaptive opponent).

H. Information-Theoretic Limits of Gradient-Based Detection

The operational envelope (§V-G) reveals a fundamental limitation: no gradient-based detector can distinguish attack from benign drift when the adversary’s updates lie within the typical set of the benign gradient distribution. This is a consequence of the information-theoretic gap between distributions, not a design oversight.

Formal intuition. Let $\mathcal{P}_{\text{honest}}$ be the distribution of honest gradient residuals $r_i^{(t)} = g_i^{(t)} - \mu^{(t)}$, and $\mathcal{P}_{\text{adv}}$ be the distribution of adversarial residuals under a cascade-aware adversary (A6). Any detection statistic $S(r)$ induces a binary classification with FPR α and TPR β . For any S , the KL divergence bounds achievable detection:

$$D_{\text{KL}}(\mathcal{P}_{\text{adv}}\|\mathcal{P}_{\text{honest}}) \geq \beta \log \frac{\beta}{\alpha} + (1 - \beta) \log \frac{1 - \beta}{1 - \alpha} \quad (20)$$

When the adversary constrains $\|r_{\text{adv}}\|_2$ within the ϵ -typical set of $\mathcal{P}_{\text{honest}}$, we have $D_{\text{KL}} \rightarrow 0$, and any detector must satisfy $\beta \leq \alpha$ (i.e., detection at or below random chance). The cascade’s per-layer thresholds calibrate this typical set: an update within all four envelope bounds is statistically indistinguishable from an honest update at that round.

Implication. The cascade is an **early-warning alarm for out-of-distribution updates**, not a general adversary-proof aggregator. The defense shifts the adversary’s cost from per-round SNR (which can be made arbitrarily large by using a sufficiently strong perturbation) to **per-round stealth**: the adversary must spread the attack over many rounds, each perturbation bounded by the envelope. The practical guarantee is not that attacks are impossible, but that they are sufficiently slow that external controls (human review, regulatory oversight, AML alerts) can intervene. This reframing—from “detect all attacks” to “bound the adversary’s throughput to an operationally manageable rate”—is the paper’s core design principle.

VI. EXPERIMENTAL DESIGN AND EXPECTED RESULTS

A. Setup

Datasets. IEEE-CIS Fraud Detection citeieee2019 (590,540 transactions, 434 features, 3.5

Non-IID split methodology. Two strategies: (1) Dirichlet allocation at $\alpha \in \{0.1, 0.5, 1.0\}$, 5 seeds each; (2) geographic splits by billing region.

Parameters. $N = 10$ clients, $R = 200$ rounds, $E = 5$ local epochs, batch size 256. Model: 3-layer MLP ($256 \rightarrow 128 \rightarrow 64 \rightarrow 1$). Learning rate: 0.001 (Adam). Requires 50–100 GPU-hours.

TABLE IV
BASELINE DEFENSE METHODS.

ID	Baseline	Mechanism	Source
B1	FedAvg	Simple averaging	[4]
B2	Krum	ℓ_2 nearest-neighbor selection	[8]
B3	Median	Coordinate-wise median	[9]
B4	Trimmed Mean	Trimmed coordinate-wise mean	[9]
B5	Bulyan	Iterative Krum + trimmed mean	[10]
B6	FLTrust	Server trust anchor (clean dataset)	[11]
B7	FoolsGold	Gradient similarity divergence	[12]
B8	RFA	Geometric median via Weiszfeld	[28]
B9	DP-FL ($\epsilon = 8$)	Gradient perturbation (DP-SGD)	[29]
B10	FLDetector	History-based anomaly detection	[13]
B11	DP-FedAvg ($\epsilon = 4$)	Gradient perturbation (DP-SGD)	[29]
B12	DP-FedAvg ($\epsilon = 1$)	Gradient perturbation (DP-SGD)	[29]
B13	Clipped Median	Norm clipping + median	Engineering variant
B14	Multi-Krum + Trimmed Mean	Ensemble defense (stateful)	Engineering variant

TABLE V
PER-ROUND COMPUTATIONAL COMPLEXITY.

Defense	Complexity	Est. Wall Clock ($N = 10, d = 100K$)
FedAvg	$O(Nd)$	$\leq 0.01s$
Krum	$O(N^2d)$	$\leq 0.1s$
Trimmed Mean	$O(Nd)$	$\leq 0.01s$
DP-FedAvg	$O(Nd) + \text{noise}$	$\leq 0.01s$
Full Defense	$O(N^2d) + \text{PCA } O(Nd^2)$	$\leq 0.8s$ (L3 bottleneck)

B. Baselines

Fourteen baselines are evaluated (Table IV), covering stateless robust aggregators (Krum, Median, Trimmed Mean, Bulyan, RFA, Clipped Median), stateful defenses (FLTrust, FoolsGold, FLDetector, Multi-Krum + Trimmed Mean), and privacy-preserving variants (DP-FedAvg at $\epsilon \in \{1, 4, 8\}$).

C. Benign-Drift Control Experiment

To empirically measure the FPR degradation predicted by Corollary 1.1 (§VII), the following control experiment is run:

- 1) **Phase 1 (stationary):** Train FedAvg on benign-only data for $W_h = 200$ rounds. Record per-round classification loss $\mathcal{L}_i^{(t)}$ for each client.
- 2) **Phase 2 (drift injection):** Continue training but inject synthetic drift at the gradient distribution level: $\Sigma_t = \Sigma_0 + \delta_t \cdot E$, where E is a random symmetric matrix with $\|E\|_2 = 1$ and δ_t increases linearly from 0 to ϵ_{drift} over P_{drift} rounds.
- 3) **Measurement:** Record the false positive rate (high-confidence flagging) at each drift level $k\epsilon_0$, where ϵ_0 is the smallest drift detectable by the L2 PCA gap.

The experiment measures three quantities:

- The **practical FPR drift threshold**: the ϵ_{drift} at which FPR_2 exceeds 5%.
- The **window-length trade-off**: whether shorter PCA recomputation interval P reduces drift sensitivity at acceptable compute cost.
- The **DP-SNR degradation**: repeat the experiment with $\epsilon_{\text{local}} \in \{10, 5, 2, 1\}$ DP noise applied before detection, measuring how DP noise compounds the drift sensitivity.

All experiments run on synthetic Gaussian data ($d = 50$, $N = 10, 20$ independent trials). Results establish the operating envelope for the field deployment.

TABLE VI
ABLATION CONFIGURATIONS.

ID	Configuration	Expected ASR (UB)
C1	No Defense (FedAvg)	≤ 0.99
C2	L1 Only (Norm/Cosine)	≤ 0.75
C3	L2 Only (Spectral)	≤ 0.65
C4	L3 Only (Temporal)	≤ 0.60
C5	L1 + L2 (no temporal)	≤ 0.55
C6	L1 + L3 (no spectral)	≤ 0.45
C7	L2 + L3 (no norm)	≤ 0.45
C8	Full Defense	≤ 0.35
C9	Cascade Fixed ($\tau_1 = 0.75$, $\tau_2 = 0.70$)	≤ 0.40
C10	Cascade Oracle (grid-searched τ)	≤ 0.35
C11	τ_Δ sweep: 3, 4, 5, 6, 7	See text
C12	W vs τ_Δ 2D heatmap	See text
C13	Warm-up: skip L3 for first 20 rounds	≤ 0.45
C14	Empty pool: revert to FedAvg when all flagged	≤ 0.50
C15	RCC inclusion vs exclusion (per-client baseline)	See text

D. Ablation and Sensitivity Configurations

Fifteen ablation configurations isolate each component’s contribution (Table VI). Configurations C9 (Cascade Fixed) and C10 (Cascade Oracle) are critical controls—they isolate whether the adaptive threshold or the cascade structure is the primary source of improvement. Configurations C11–C15 test the sensitivity of reputation warm-up, detection margin, and system-level robustness.

In addition, a **hyperparameter sensitivity grid** is planned over key thresholds:

- $\tau_{\text{norm}} \in \{1.0, 1.25, 1.5, 1.75, 2.0\}$ (norm filter)
- $\tau_{\text{cos}} \in \{0.3, 0.4, 0.5, 0.6\}$ (cosine filter)
- $\tau_\Delta \in \{3, 4, 5, 6, 7\}$ (per-client deviation margin, σ threshold)
- $W_h \in \{100, 150, 200, 250, 300\}$ (warm-up window length)
- $W \in \{30, 40, 50, 60, 70\}$ (sliding-window length)

This grid isolates whether projected results depend on tight tuning or the architectural structure. Expected variance across reasonable threshold settings is reported with the sensitivity analysis.

Temporal cross-validation split. To align evaluation with the temporally-aware claim, a time-series expanding-window split is used: models are trained on rounds $1 \dots t$ and evaluated on round $t + 1$, rolling forward across the 200-round horizon. This contrasts with static random splits and tests robustness to concept drift.

E. Evaluation Metrics

Beyond the primary Attack Success Rate (ASR) and honest False Positive Rate (FPR), the following metrics characterize the cascade’s operational behavior:

- **Reputation Precision** = $TP/(TP + FP)$ — fraction of flagged clients actually malicious.
- **Reputation Recall** = $TP/(TP + FN)$ — fraction of malicious clients actually flagged.
- **Reputation AUC** — area under ROC curve for the L3 classification threshold.
- **False Decline Rate (FDR)** — fraction of benign updates rejected by the cascade (proxy for customer friction).

TABLE VII
PROJECTED ASR UPPER BOUNDS (UB): FULL DEFENSE VS. BASELINES UNDER ASSUMPTIONS STATED IN §VI-F. UPPER BOUNDS ARE CONSISTENT WITH EACH DEFENSE’S THEORETICAL GUARANTEE; POINT ESTIMATES ARE RESERVED FOR EXPERIMENTAL VALIDATION.

Disclaimer: Projected upper bounds informed by theory, not empirical measurement. Experimental validation in progress.						
Defense	A1	A2	A3	A4'	A5	Theoretical Guarantee
FedAvg	≤ 0.99	≤ 0.99	≤ 0.99	≤ 0.99	≤ 0.99	None (vanilla FL)
Krum	≤ 0.15	≤ 0.70	≤ 0.45	≤ 0.75	≤ 0.60	ℓ_2 nearest-neighbor selection
Trimmed Mean	≤ 0.10	≤ 0.60	≤ 0.40	≤ 0.70	≤ 0.55	Coordinate-wise robust aggregation
FLTrust	≤ 0.15	≤ 0.60	≤ 0.35	≤ 0.65	≤ 0.50	Server trust anchor
FoolsGold	≤ 0.20	≤ 0.65	≤ 0.30	≤ 0.60	≤ 0.50	Gradient similarity divergence
FLDetector	≤ 0.25	≤ 0.50	≤ 0.40	≤ 0.60	≤ 0.45	History-based anomaly detection
Full Defense	≤ 0.10	≤ 0.35	≤ 0.30	≤ 0.50	≤ 0.40	Gated cascade (3-layer)

- **Matthews Correlation Coefficient (MCC)** — balanced metric robust to the class imbalance inherent in fraud settings (few attackers).

Trial protocol. All experiments use **10 independent trials** (seeds 0–9) with three sources of randomness independently varied:

- 1) Non-IID partition seeds (Dirichlet $\alpha \in \{0.1, 0.5, 1.0\}$, 5 seeds each)
- 2) Client sampling order per round
- 3) Attack starting round ($t_0 \in \{10, 20, 50, 100\}$)

Results are reported as mean $\pm$ standard deviation across the 10 seeds, not within-run confidence intervals.

F. Expected Results

Table VII: Theoretically projected Attack Success Rate—Full Defense vs. Baselines.

Disclaimer: The numerical values below are **theoretically projected from formal analysis** (§VII) and architectural reasoning, not experimentally measured. They represent the expected range under the assumptions stated in §VII (stationary covariance, bounded perturbations $\delta \leq 0.15$, honest majority). Experimental validation is in progress. Values should be read as hypotheses suggested by the theory, not as validated outcomes.

Expected projected findings (to be validated): Stateless baselines are projected to fail under A2 and A4' (temporal grinding and insider collusion): their upper bounds are ≥ 0.50 across all baselines except Trimmed Mean and FLTrust. Each layer’s removal is projected to increase ASR by ≥ 10 pp, with the largest drop from L3 removal (C5 vs. C8). Adaptive threshold is projected to add ~ 7 pp (C8 vs. C9), while the cascade structure contributes the majority of improvement (C9 vs. C1). Honest FPR is projected at $\leq 1.6\%$, consistent with §VII. These projections are upper bounds informed by theory, not empirical measurements.

VII. FORMAL ANALYSIS

A. Cascade Error Propagation Bound

We bound the gated cascade’s honest false positive rate. Let FPR_k be the FPR of layer k . The cascade FPR is:

$$\text{FPR}_{\text{cascade}} = \text{FPR}_1 + (1 - \text{FPR}_1 - \text{TPR}_1) \cdot [\text{FPR}_2 + (1 - \text{FPR}_2 - \text{TPR}_2) \cdot \text{FPR}_3] \quad (21)$$

Theorem 1 (Cascade FPR under stationary Σ). Assume the benign gradient covariance Σ is stationary over the evaluation window W . Under the statistical model of Section 3.2 (zero-mean update residuals, i.i.d. across rounds), the cascade FPR is bounded by Stewart’s perturbation theorem. For bounded perturbations $\|\Delta_i\| \leq \delta$, $k = 3$ principal components, and $\tau_2 = 0.4$, $\delta \leq 0.15$:

$$\mathbb{P}[e_i > \tau_2 \mid \text{honest}] \leq 2 \cdot \exp\left(-\frac{(\tau_2 - \delta C)^2}{2\sigma^2}\right) \quad (22)$$

giving $\text{FPR}_2 \leq 0.012$. Combined with $\text{FPR}_1 \leq 0.003$ and $\text{FPR}_3 \leq 0.001$:

$$\begin{aligned} \text{FPR}_{\text{cascade}} &\leq 0.003 + (0.997 - \text{TPR}_1) \\ &\cdot [0.012 + (0.988 - \text{TPR}_2) \cdot 0.001] \approx 0.016 \end{aligned} \quad (23)$$

Implication. Under stationary benign gradient covariance, the cascade maintains honest $\text{FPR} \leq 1.6\%$ under bounded perturbations, bounding the feedback-loop risk.

Interpretation note. The per-layer FPR_k values represent the probability that layer k **confidently rejects** an honest update ($c_k < \theta_{\text{low}}$), not the raw test-level Type I error. Updates in the uncertainty zone ($\theta_{\text{low}} < c_k < \theta_{\text{high}}$) are escalated to the next layer, not rejected. This distinction is essential in a gated cascade: a per-layer test with moderate raw flagging rate (e.g., ~ 0.067 for $\tau_{\text{norm}} = 1.5\sigma$ at L1) can achieve low FPR_1 via a calibrated θ_{low} that rejects only extreme outliers with high confidence.

Corollary 1.1 (Drift-affected FPR). When Σ is non-stationary with bounded drift rate $\|\Delta\Sigma\|_2 \leq \varepsilon_{\text{drift}}$, the FPR bound degrades by at most:

$$\text{FPR}_2(\varepsilon_{\text{drift}}) \leq \mathbb{P}\left(e_i > \tau_2 - \frac{\varepsilon_{\text{drift}}}{\text{gap}} \mid \text{honest}\right) \quad (24)$$

where $\text{gap} = \lambda_k - \lambda_{k+1}$ is the eigenvalue gap of Σ_0 , and e_i is the PCA reconstruction error of client i ’s update residual under Σ_0 . This is a **tail probability**, not a closed-form operating point—numerical FPR claims require empirical $\varepsilon_{\text{drift}}$ measurement. The $\varepsilon_{\text{drift}}/\text{gap}$ form (first power) follows from the Davis-Kahan $\sin\Theta$ theorem (29). An approximate rule: if $\varepsilon_{\text{drift}}/\text{gap} \leq 0.05$, the FPR increase is $< 1\%$; at $\varepsilon_{\text{drift}}/\text{gap} \approx 0.167$, the shift can degrade FPR to 10–50%. The sliding-window PCA recomputation interval P should be chosen to keep per-interval drift bounded by the gap: $P \leq \text{gap}/\varepsilon_{\text{drift}}$.

1) *Connecting FPR Bound to Projected ASR:* The FPR bound establishes false alarm reliability but does not directly bound attack success rate (ASR)—the primary adversary objective. Formal ASR bounds require empirical measurement of per-layer true positive rates (TPR_k), which depend on attack magnitude, collusion scale, and gradient statistics. Absent experimental validation, the projected ASR values in Table VII follow from the layer-wise detection structure under the conservative assumption that each layer’s TPR is proportional to its separability margin (the gap between honest and malicious gradient statistics). Quantitative ASR bounds are deferred to the expanded version with cloud-based experiments.

B. Convergence of Adaptive Threshold Dynamics

The threshold update defines a dynamical system on $(\theta_{\text{high}}, \theta_{\text{low}})$:

$$\theta^{(t+1)} = \theta^{(t)} + \eta(t) \cdot h(\theta^{(t)}, \rho^{(t)}) \quad (25)$$

where h captures the attack-response signal. Under stationary $\rho^{(t)}$ with mean ρ_0 , the system converges to a neighborhood of $\theta^* = \{\theta : \rho(\theta) = \rho_0\}$, provided h is a contraction in θ .

Lipschitz condition (informal). The function h is Lipschitz in θ with constant $L_h = |\eta_{\text{attack}} - \eta_{\text{relax}}| \cdot |\partial\rho/\partial\theta|$. For the parameters in §IV-E, $L_h \approx 0.05 < 1$ —satisfying the contraction condition. We note that this is an order-of-magnitude estimate: $|\partial\rho/\partial\theta|$ depends on the empirical distribution of anomaly scores, which is non-stationary and client-dependent. The specific constant requires measurement from deployment data.

Convergence neighborhood. When $L_h < 1$, the tracking error is bounded as:

$$\|\theta^{(t)} - \theta^*\| \leq O\left(\frac{\eta\sigma_\rho}{1 - L_h}\right) \quad (26)$$

where σ_ρ is the variance of the attack-rate estimate. Plugging the illustrative values $\eta = 0.05$, $\sigma_\rho \leq 0.1$, $L_h \leq 0.05$ gives an error of order ~ 0.005 , but the $O(\cdot)$ constant depends on the attractor geometry and is not derived here. Under non-stationary attack patterns, the threshold tracks the moving optimum with bounded lag—characterized as a **control system** with tracking error proportional to the drift rate.

Two-timescale structure. The threshold dynamics (25) operate on a slower timescale ($\eta_{\text{attack}} = 0.15$, $\eta_{\text{relax}} = 0.05$) than the gradient descent ($\eta = 0.005$ – 0.01). This separation enables a two-timescale stochastic approximation analysis (Borkar, 1997; Borkar & Meyn, 2000): the fast gradient descent tracks the stationary point of the current threshold, while the slow threshold dynamics track the optimal threshold for the current attack regime. The tracking error between the coupled system and the decoupled approximation is $O(\eta \cdot \tau_{\text{mix}})$, where τ_{mix} is the mixing time of the reputation chain (§IV-D). A rigorous bound requires deriving the constant—we establish the framework and leave the constant derivation as future work.

Transient coupling justification. During transient attack phases, the Lipschitz constant L_h depends on the attack strength $\|\Delta g\|$ and frequency f_{attack} :

$$L_h(t) \leq L_{h,0} + \beta \cdot f_{\text{attack}}^{(t)} \cdot \|\Delta g\|/\sigma_{R,i} \quad (27)$$

where β is a configurable sensitivity parameter. Under bounded adversarial capability A6 ($f_{\text{attack}} \leq 0.3$, $\|\Delta g\| \leq \tau_{\text{norm}}$), the transient component is bounded: $L_h(t) \leq 0.05 + 0.3 \cdot 2.0/0.015 \cdot \beta$. For $\beta \leq 10^{-4}$, this keeps $L_h < 1$ during attacks. The specific constant requires empirical measurement; the bound framework establishes that $L_h(t) < 1$ is achievable under the A6 envelope.

Bounded-drift extension (concept drift). The Stewart bound above assumes stationary Σ . Credit card fraud exhibits concept drift—shifting spending patterns, emergent fraud

strategies—that perturbs Σ over time. Extending to the non-stationary case:

Drift model. Let Σ_t be the benign gradient covariance at round t . Bound the drift over a sliding-window PCA recomputation interval P :

$$\|\Sigma_{t+P} - \Sigma_t\| \leq \varepsilon_{\text{drift}} \quad (28)$$

Davis-Kahan sin Θ bound. The top- k principal subspace $U_k^{(t)}$ shifts by at most:

$$\|\sin \Theta(U_k^{(t+P)}, U_k^{(t)})\| \leq \frac{\|\Sigma_{t+P} - \Sigma_t\|}{\lambda_k - \lambda_{k+1}} \leq \frac{\varepsilon_{\text{drift}}}{\text{gap}} \quad (29)$$

where $\text{gap} = \lambda_k - \lambda_{k+1}$ is the eigenvalue gap. The L2 reconstruction error for a unit-norm honest gradient changes by:

$$|\hat{e}_i - e_i| \leq \|UU^T - VV^T\| \leq \|\sin \Theta\| \leq \frac{\varepsilon_{\text{drift}}}{\text{gap}} \quad (30)$$

Note the absence of k in the numerator: the subspace rank does not directly amplify the drift effect—it enters only through the eigenvalue gap, which typically decreases with k .

Drift-affected FPR bound. The FPR under drift is a tail probability, not a closed form:

$$\text{FPR}_2(\varepsilon_{\text{drift}}) \leq P\left(e_i > \tau_2 - \frac{\varepsilon_{\text{drift}}}{\text{gap}} \mid \text{honest}\right) \quad (31)$$

This depends on the quantile function of honest reconstruction errors. An approximate rule: if $\varepsilon_{\text{drift}}/\text{gap} \leq 0.05$, the FPR increase is $< 1\%$; at $\varepsilon_{\text{drift}}/\text{gap} \approx 0.167$ (example: $0.05/0.3$), the shift can push many honest scores above threshold, degrading FPR to 10–50%. The sliding-window PCA recomputation interval P should be chosen to keep the per-interval drift bounded by the gap: $P \leq \text{gap}/\varepsilon_{\text{drift}}$.

C. Fairness Guarantee via Reputation Forgetting

Theorem 1 (Reputation Floor). For any client whose average anomaly score over any W -round window is at least 0.95 (i.e., predominantly honest behavior):

$$R_i^{(t)} \geq R_{\text{SS}} = 0.85 \quad \text{for all } t > t_0 \quad (32)$$

Proof sketch. Under the sliding-window reputation mechanism, $R_i^{(t)}$ is the mean of $a_i^{(s)}$ over the last W rounds. For an honest client with per-round anomaly score ≥ 0.95 and steady-state floor $R_{\text{SS}} = 0.85$, the window average never falls below R_{SS} regardless of transient false flags. The R_{SS} floor applies after the window computation as a hard lower bound.

Corollary 1 (Max Consecutive False Flags). For honest clients, $\text{MCFF} \leq t_0 = 10$ rounds. Since $R_{\text{SS}} = 0.85$ exceeds the per-client detection threshold $T_i = \bar{R}_i - \tau_\Delta \cdot \sigma_{R,i}$ for any honest client (typical $\bar{R}_i \geq 0.90$, $\sigma_{R,i} \leq 0.015$, giving $T_i \leq 0.825$), the reputation floor ensures no honest client is permanently excluded. We note that this is a **transient anomaly protection** mechanism, not a formal fairness guarantee—subgroup-specific FPR analysis (EOA disparate impact) is discussed in §VIII.

TABLE VIII
TEE THREAT RISK REGISTER AND GRACEFUL DEGRADATION PATHS.

Threat	Severity	Mitigation in Design	Graceful Degradation
Side-channel (timing/power/cache)	High	Constant-time attestation, memory encryption	Fall back to DP-only (cryptographic) mode
Attestation key compromise	High	Dual-layer attestation, key rotation schedule	Consortium emergency key refresh
Rollback attack	Medium	Chain-of-hash on published digest	Detect and halt; audit trace
Supply chain (hardware backdoor)	Low	Open-source firmware audit, TPM-measured boot	—
SGX deprecation	Medium	Abstraction over DCAP/ITDX/SEV-SNP	Use AMD SEV-SNP or NVIDIA CC

D. Privacy-Robustness Tension

Spectral (L2) and reputation (L3) detection require raw gradient access, creating a tension with the privacy guarantees typically expected in FL. Previous versions of this design relied solely on TEE attestation to bridge this gap. The solution plan restructures the pipeline so that a formal DP guarantee is provided independently of TEE trust.

1) Revised Processing Pipeline:

$$\begin{aligned} [\text{Raw grad.}] &\rightarrow \text{DP } (e_{\text{local}}) \rightarrow \text{L1} \rightarrow \text{L2} \\ (\text{noised}) &\rightarrow \text{L3} \rightarrow \text{SecAgg } (e_{\text{global}}) \end{aligned}$$

The privacy guarantee is **cryptographic (DP)**, not hardware-attested: each client applies local differential privacy noise with parameter $\varepsilon_{\text{local}}$ to their gradient before it enters the detection cascade. L2 and L3 operate on DP-noised gradients. The TEE becomes a defense-in-depth layer protecting the aggregation logic and DP accounting, rather than the sole privacy anchor.

a) Consequences.:

- The privacy guarantee is independent of TEE trust—satisfies GDPR Art. 25 (data protection by design) and Art. 32 (state of the art).
- DP noise reduces L2/L3 detection SNR. The degradation must be characterized empirically (see experimental plan, §VI-C).
- If detection power degrades unacceptably at $\varepsilon_{\text{local}}$ values required for GDPR compliance, the alternative is to frame the architecture honestly as “prioritized detection over privacy under audited TEE”—a deployment choice for the consortium, not a research gap.

2) *Attestation Design (Dual-Layer):* Two verification layers ensure enclave integrity:

- **Layer 1 — Independent auditor (mandatory):** A neutral entity (Big 4 firm, industry body, or separate legal entity) operationally separate from the server host runs attestation daily and on every enclave restart. Signed attestation reports (enclave measurement hash, code version, TCB freshness) are published to a consortium-accessible audit log.
- **Layer 2 — Client opt-in (optional):** Any consortium member can independently attest the enclave using the platform’s remote attestation protocol. The enclave’s public verification key and expected measurement hash are published in the consortium agreement.

3) TEE Risk Register:

4) SMPC / DP / TEE Comparison:

5) *Disclosed Risks:* Side-channel attacks on SGX (cache timing, page-fault, speculative execution—Plundervolt, ZombieLoad) have been demonstrated in controlled settings. Mitigations include SEV-SNP and SGX v2 microcode updates. The enclave sealing key must be managed to survive

TABLE IX
COMPARISON OF PRIVACY TECHNOLOGIES FOR GRADIENT
CONFIDENTIALITY.

Dimension	Pure SMPC	DP-only	TEE-only (prior)	TEE + DP (proposed)
Privacy guarantee	Cryptographic	DP (ϵ)	Hardware attestation	DP ($\epsilon_{\text{local}} + \epsilon_{\text{global}}$) + HW
Auditability	High	Medium (noise accounting)	Low (black box)	Medium (attested code + DP)
Computational cost	Very high ($O(d^2)$)	Low	Medium	Medium
Robust aggregation	Limited	Compatible	Fully compatible	Fully compatible
GDPR Art. 25/32	High	High	Low (without crypto)	High
Detection SNR	Full	Reduced	Full	Reduced

reboots (standard TEE key management). Context-switching into the enclave adds 5–15% compute overhead; for $N = 10$ clients at $d = 500$ parameters per round, this is negligible.

6) *Regulatory Fit*: Under GDPR Art. 28 (processor), the TEE with dual-layer attestation and local DP noise constitutes “sufficient guarantees to implement appropriate technical and organisational measures.” The auditor’s continuous attestation replaces SecAgg’s mathematical guarantee with an audited procedural guarantee—weaker in theory, but defensible under the fraud-detection exemption (Art. 6(1)(d), 9(2)(f)) and PSD2/PSR implementing acts. The cryptographic DP layer ensures the privacy guarantee is independent of hardware trust.

VIII. REGULATORY AND ETHICAL CONSIDERATIONS

A. GDPR Compliance

Gradient-as-Personal-Data. Under *Nowak* (C-434/16), gradient updates derived from personal transaction data are **personal data** under Art. 4(1). A mandatory Data Protection Impact Assessment (Art. 35) is required.

Automated Decision-Making (Art. 22). The training-vs.-inference separation is well-justified: spectral detection operates on gradients during training, not on transactions during inference.

Data Processor vs. Joint Controller (Art. 26). If the server operator determines aggregation methods and membership, it is likely a **joint controller**.

Cross-Border Transfer (Art. 44–49). Under *Schrems II* [31], transfers to jurisdictions without adequate protection require Transfer Impact Assessments.

Technical and organisational measures (Art. 28, 32). The TEE with dual-layer attestation (§VII-D) constitutes “sufficient guarantees to implement appropriate technical and organisational measures” under Art. 28(1). The independent auditor’s continuous attestation and the published audit log satisfy the accountability requirement (Art. 5(2)). Each client bank can verify the enclave’s code integrity before submitting data, satisfying Art. 32’s requirement for encryption and confidentiality of processing.

B. Privacy Accounting

The revised pipeline (local DP before detection, §VII-D) provides **cryptographic privacy accounting** independent of TEE trust. Two tiers of DP noise apply:

- **Local DP (ϵ_{local}):** Each client applies local differential privacy noise to their gradient before it enters the detection cascade. L1, L2, and L3 operate on DP-noised gradients—reducing detection SNR but providing

TABLE X
SR 11-7 MODEL RISK MANAGEMENT MAPPING.

Requirement	Mapping to the Framework
Monitoring (§III.B)	Track FPR autocorrelation, MCFF, reputation distribution
Governance (§IV)	Human-review trigger at 2σ escalation
Out-of-tolerance	Auto-disable if ASR > 0.50 over 50 rounds
Concept drift	30-round correlation: fraud rate vs. reputation
Override process	Documented appeal within 24h; outcome log

a formal privacy bound at every intermediate processing step.

- **Global DP (ϵ_{global}):** The released global model $\theta^{(T)}$ is trained via DP-FedAvg with $\epsilon_{\text{global}} \in \{\infty, 8, 4, 1\}$, providing the formal guarantee that the published model does not memorize individual transactions.
- **Composition:** The total privacy loss is $\epsilon_{\text{total}} = \epsilon_{\text{local}} + \epsilon_{\text{global}}$ under basic composition (Rényi DP accounting in the full version). The detection cascade operates under ϵ_{local} , not ϵ_{global} , so the SNR degradation is bounded by ϵ_{local} alone.

Trade-off disclosure. DP noise reduces the detection power of L2 spectral and L3 reputation scoring. This degradation must be characterized empirically (see experimental plan, §VI-C). If detection power degrades unacceptably at ϵ_{local} values necessary for GDPR compliance, the alternative architecture—raw-gradient inspection within an audited TEE without local DP—is a deployment choice for the consortium. The paper does not advocate one path; it specifies the trade-offs.

C. SR 11-7 Model Validation

D. Fairness Regulation (ECOA, FCRA)

Three fairness risks identified: (1) Per-subgroup honest FPR asymmetry (threshold: no subgroup FPR $> 2 \times$ overall rate); (2) geographic proxy discrimination; (3) ECOA adverse action notices. The reputation forgetting mechanism (§VII) directly addresses structural fairness risk.

E. AML/CFT Override Obligations

The system includes an `SAR_override` flag: when a flagged update involves a transaction exceeding the local reporting threshold, an automated alert for human review is generated, recommending a Suspicious Activity Report investigation regardless of the flag’s accuracy. The final SAR filing decision remains with the compliance officer to ensure legal accountability.

F. Consortium Governance Structure

A formal governance agreement is essential for deployment in a regulated financial consortium. The following elements are specified for incorporation into the consortium’s legal framework:

The governance framework operates alongside the TEE attestation mechanism (§VII-D): the independent auditor (Layer 1 attestation) reports to the SPV’s board, and the audit

TABLE XI
CONSORTIUM AGREEMENT STRUCTURE.

Element	Specification
Legal entity	Special Purpose Vehicle (SPV) with joint ownership proportional to reputation-weighted contribution
Model IP	Global model $\theta^{(T)}$ jointly owned; each bank receives a royalty-free license for fraud scoring
Liability	Capped at each bank’s annual consortium fee; liability for erroneous scores proportional to reputation weight
Onboarding	Probationary period of $W = 50$ rounds; R_i initialized at 0.5 during probation
Exit	W -round notice period; reputation gradually forgotten over W rounds

log is accessible to all members. Disputes over model updates are resolved by reverting to the last attested checkpoint.

G. Cross-Jurisdictional and Sovereign Trust Considerations

This paper targets cross-border banking, yet prior versions omitted analysis of cross-jurisdictional legal conflicts. We now identify key threats and mitigations.

TEE key management geography. Intel SGX/TDX and AMD SEV-SNP attestation keys are managed by US-headquartered companies. Under the US CLOUD Act (2018), a US law enforcement agency can compel these companies to assist in subverting the enclave. For an EU bank processing EU citizens’ data in a TEE whose trust anchor is a US company, this creates a *Schrems II* violation: the data does not receive “essentially equivalent” protection to GDPR.

Mitigations:

- 1) Sovereign attestation services using non-US key hierarchies (e.g., EU-based TEEs with European key management, or open RISC-V TEEs with independent certification).
- 2) Geographic residency requirements for attestation key management.
- 3) The hybrid DP + TEE architecture (§VII-D) ensures the formal privacy guarantee does not depend on TEE trust—it is mathematical (DP).

Data localization vs. AML record retention. EU banking secrecy laws (e.g., German §24c KWG, French Monetary and Financial Code) require data to remain within the jurisdiction. The DP-based privacy guarantee must be reconciled with the fact that fraud detection data may be exempt from right-to-erasure under GDPR Art. 23. The architecture separates *training data* (subject to DP/right-to-erasure) from the *fraud detection model and audit log* (subject to AML retention).

Cross-jurisdiction compliance mismatch. GDPR’s right to erasure conflicts with FINMA’s 10-year record retention requirement. The design addresses this through a data retention policy that respects both obligations: gradient data is ephemeral (per-round, not stored), the global model is retained for the model lifecycle, and the audit log is retained according to the strictest applicable retention schedule.

H. Explainability and Right to Explanation

Under GDPR Art. 22 and ECOA/FCRA adverse-action requirements, a declined transaction must be explainable to the customer. The spectral and reputation anomaly scores produced by the cascade describe *why the model update was flagged*, not *why an individual transaction was declined*. We address this through a **surrogate SHAP model with local fidelity audit**:

- **Local fidelity requirement.** For each decile of the applicant score distribution, the surrogate SHAP model must achieve:
 - Weighted local $R^2 \geq 0.85$ within each decile.
 - Maximum individual-level absolute SHAP error ≤ 0.15 (relative to true model output delta).
 - If local fidelity drops below threshold for any decile, that decile’s explanations are marked “estimated — contact [regulatory authority] for individualized explanation.”
- **Proxy dataset governance.** The surrogate is trained on a consent-authorized proxy dataset with explicit specification:
 - **Size:** $N_{\text{proxy}} \geq 10,000$ (or 5% of training set, whichever larger), stratified by outcome class (fraud/non-fraud) and by membership institution.
 - **Consent:** Explicit opt-in with right to withdrawal; proxy data cannot contain PII. Legal basis: GDPR Art. 6(1)(d) fraud-prevention consent.
 - **Retention:** Tied to model lifecycle; automatic deletion 90 days after model decommissioning.
 - **Audit trail:** SHA-256 hash of proxy dataset published to consortium blockchain at training start.
- **Audit trail.** The aggregator TEE signs each global model update hash along with the corresponding anomaly scores, providing a tamper-evident audit trail for regulatory inspection (SR 11-7, Art. 5(2) accountability).
- **Legal caveat.** Proxy-based explanations are *estimates*, not legally binding explanations under ECOA §615 or GDPR Art. 22. Institutions must maintain their own individualized explanation capability for adverse actions.

IX. DISCUSSION AND LIMITATIONS

A. Experimental Validation Status

This paper is a design-stage specification. Expected results derive from formal analysis (§VII) and architectural reasoning. **Experimental validation requires 50–100 GPU-hours on cloud infrastructure and is in progress.**

B. Concept Drift Management

The formal analysis (§VII-A) establishes FPR bounds under the assumption of stationary benign gradient covariance Σ . In operational deployment, fraud patterns evolve—non-stationary Σ degrades detection reliability as characterized by Corollary 1.1. Three complementary strategies manage this drift:

- 1) **Sliding-window PCA:** Rather than cumulative PCA over the full training history, the L2 spectral layer

TABLE XII
COUNTER-ARGUMENTS AND RESPONSES.

Concern	Our Response	Residual Risk
Cascade accumulates FPRs	§VII-A: 1.6% honest FPR bound	Bound depends on $\delta \leq 0.15$
Server compromise excluded	Standard assumption; TEE future work	Realistic vector
No oracle baseline	C9, C10 in ablation test this	Without experiments, estimated
Convergence not proven	§VII: control system	Non-stationary patterns may oscillate

recomputes its principal subspace every P rounds ($P \leq \text{gap}/\varepsilon_{\text{drift}}$). The window discards stale gradient statistics, bounding the accumulated drift between recomputations.

- 2) **Baseline recalibration trigger:** The per-client statistics $(\bar{R}_i, \sigma_{R,i}, RCC_i^{(\text{base})})$ are recalibrated when the global model’s validation loss plateaus or increases—an indicator that the underlying data distribution has shifted sufficiently to invalidate the original baselines.
- 3) **Separate drift detection:** The PCA reconstruction error of the aggregated benign gradient is monitored as a drift indicator. If $\frac{1}{N} \sum_i e_i^{(t)}$ exceeds 2σ of its running mean, a drift alert is raised and recalibration is triggered.

These mechanisms do not eliminate drift vulnerability—they bound its operational impact. A drift-resilient estimator (e.g., adaptive eigenbasis tracking) is a direction for future work.

C. Red-Team Assessment

D. Missing Stakeholder Perspectives

The discussion so far treats the consortium as a single entity. In practice, three distinct stakeholders have conflicting incentives that the architecture must address:

Regulator (central bank / financial authority). The regulator’s primary concern is systemic stability: a compromised global model causes false declines across all member banks. Regulators require:

- Independent audit trail for every model update (addressed via TEE attestation log, §VII-D).
- Transparency into the per-client flagging rationale (addressed via surrogate SHAP with local fidelity audit, §VIII-H).
- Mechanism design aligning bank incentives with consortium health (addressed via Shapley-based contribution scoring, §IV-G).

Member bank. A bank’s incentives are not aligned with the consortium’s: a false decline at their institution harms their customer relationship, while a false acceptance at another bank due to a poisoned model does not. Banks may:

- Over-contribute benign-looking gradients to build reputation while submitting poor-quality data (addressed via Shapley marginal contribution measurement).
- Opt out of sharing high-value transaction features (addressed via the feature selection agreement in the consortium governance framework, §VIII-F).
- Withdraw from the consortium after contributing baseline data, free-riding on future improvements (a governance

risk, not an architectural one; addressed via contractual lock-in periods).

Honest client (customer). The customer is the ultimate data subject and the party harmed by both false declines and uncaught fraud. Their perspective is often omitted:

- The customer has no direct relationship with the consortium—only with their member bank. Transparency is mediated by the bank’s own adverse-action notices (ECOA §615, GDPR Art. 22).
- The customer’s privacy guarantee is cryptographic ($\varepsilon_{\text{local}} + \varepsilon_{\text{global}}$), not hardware-attested, ensuring it survives TEE vulnerabilities.
- Recourse for a disputed decline remains with the customer’s bank, not the consortium—the architecture does not change the liability chain under PSD2/PSR.

The architecture does not resolve all incentive misalignments. It specifies the detection primitives and leaves the governance-layer mechanism design (reputation tokenomics, slashing conditions, withdrawal penalties) as future work under consortium governance.

E. Limitations

Key limitations include: server compromise (TEE reduces but does not eliminate this risk—enclave side-channels remain an attack surface); cold-start window ($t_0 = 10$ rounds, reduced from 20); synthetic identity fraud unaddressed; $N = 10$ clients only (real consortia may see member churn, sub-100ms latency constraints, and heterogeneous compute across institutions—none modeled here); fixed A2 schedule (not adaptive, though A6 in §V-G begins to address this). The sliding-window size $W = 50$ is a design heuristic without formal optimality characterization. The TEE-based privacy architecture (§VII-D) replaces cryptographic SecAgg with an attested hardware guarantee—weaker in theory, but the practical residual risk is bounded by the attestation audit cadence and the enclave’s disclosed side-channel mitigations. The sliding-window mechanism replaces the EMA that was present in earlier versions of this design, resolving the EMA half-life sensitivity concern raised during internal review.

F. Ethical and Societal Implications

False decline harm as design constraint. Any non-zero honest FPR causes legitimate transaction declines. Vulnerable customers may face material hardship. Rather than a post-hoc consideration, the FPR bound (§VII-A) is treated as a first-order design constraint: the cascade’s 1.6% bound is derived from the requirement that false declines remain below deployable thresholds. Subgroup-specific FPR monitoring and automatic fairness review triggers are part of the planned governance layer.

Competitive intelligence leakage. The server observes gradients reflecting each bank’s transaction distribution. The TEE architecture (§VII-D) mitigates this: gradients are processed inside the enclave, and only anomaly scores and reputation weights leave the trusted boundary. The server operator can see that gradients were processed but cannot

inspect their content. This is weaker than cryptographic solutions (functional encryption, split learning) in theory, but is compatible with L2 spectral detection and provides a deployable guarantee through attested hardware isolation. The enclave’s side-channel attack surface remains the residual risk.

Systemic risk concentration. Circuit-breaker mechanisms and fallback procedures are essential.

Window drift monitoring. The sliding-window reputation mechanism ($W = 50$) should be monitored for drift in the distribution of window scores across clients. A sudden compression of the score distribution (all clients converging towards $R = 1$) may indicate a coordinated reputation-inflation attack. An autocorrelation alert is triggered if the mean window score changes by $> 2\sigma$ over 10 rounds.

X. CONCLUSION

Cross-silo FL for credit card fraud detection faces a threat that existing Byzantine-robust aggregation methods are not designed for: **temporally-adaptive, incentive-driven poisoning** by financially-motivated adversaries. The fundamental blind spot is statelessness—per-round defenses cannot detect attackers who alternate between malicious and benign behavior across rounds.

We have presented a **gated cascade defense framework** with three complementary layers: norm/cosine filtering (rapid rejection), spectral anomaly detection (coordinated threats), and sliding-window reputation scoring (slow poisoning with hard memory bound), connected by an adaptive threshold escalation policy. Formal analysis establishes a $\sim 1.6\%$ honest FPR bound, convergence neighborhoods for threshold dynamics, and transient anomaly protection via reputation steady-state floor. Regulatory compliance mapping addresses GDPR, SR 11-7, ECOA, and AML/CFT obligations.

This paper is a design-stage specification. Expected results project 0.25 ASR for the full defense vs. 0.92 for undefended FedAvg, with cascade structure contributing the majority of improvement and adaptive thresholds adding ~ 7 pp. Experimental validation is planned on cloud infrastructure.

Acknowledgments

This work was supported by the IFD-Fintech research project. The authors thank the anonymous reviewers for their constructive feedback. No external funding was received for this design-stage specification.

REFERENCES

- [1] Nilson Report, “Card fraud losses reach \$28.65 billion,” Report 1232, 2023.
- [2] Q. Yang, Y. Liu, T. Chen, and Y. Tong, “Federated machine learning: Concept and applications,” *ACM Transactions on Intelligent Systems and Technology*, vol. 10, no. 2, pp. 1–19, 2019.
- [3] P. Kairouz *et al.*, “Advances and open problems in federated learning,” *Foundations and Trends in Machine Learning*, vol. 14, no. 1–2, pp. 1–210, 2021.
- [4] B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y Arcas, “Communication-efficient learning of deep networks from decentralized data,” in *Proceedings of AISTATS*, 2017, pp. 1273–1282.
- [5] L. Lamport, R. Shostak, and M. Pease, “The byzantine generals problem,” *ACM Transactions on Programming Languages and Systems*, vol. 4, no. 3, pp. 382–401, 1982.
- [6] D. Alistarh, Z. Allen-Zhu, and J. Li, “Byzantine stochastic gradient descent,” in *Advances in NeurIPS*, 2018, pp. 4613–4623.
- [7] Z. Allen-Zhu, F. Ebrahimiaghazaleh, J. Li, and D. Alistarh, “Byzantine-resilient non-convex stochastic gradient descent,” in *Proceedings of ICLR*, 2021.
- [8] P. Blanchard, E. M. E. Mhamdi, R. Guerraoui, and J. Stainer, “Machine learning with adversaries: Byzantine tolerant gradient descent,” in *Advances in NeurIPS*, 2017, pp. 119–129.
- [9] D. Yin, Y. Chen, R. Kannan, and P. Bartlett, “Byzantine-robust distributed learning: Towards optimal statistical rates,” in *Proceedings of ICML*, 2018, pp. 5650–5659.
- [10] R. Guerraoui, S. Rouault *et al.*, “The hidden vulnerability of distributed learning in byzantium,” in *Proceedings of ICML*, 2018, pp. 3521–3530.
- [11] X. Cao, M. Fang, J. Liu, and N. Z. Gong, “FLTrust: Byzantine-robust federated learning via trusted data,” in *Proceedings of IEEE S&P*, 2021, pp. 652–669.
- [12] C. Fung, C. J. M. Yoon, and I. Beschastnikh, “FoolsGold: A defense against data poisoning in federated learning,” in *Proceedings of WWW*, 2020, pp. 126–136.
- [13] Z. Zhang, L. Jia, H. Wang, and Z. Lu, “FLDetector: Defending federated learning against model poisoning via detecting malicious clients,” in *Proceedings of ACM CCS*, 2022, pp. 1923–1937.
- [14] M. A. A. Salam, S. M. Darwish, and T. H. A. Soliman, “Federated learning for credit card fraud detection with data balancing,” *IEEE Access*, vol. 12, pp. 3378–3393, 2024.
- [15] L. Zheng, J. Wang, and H. Liu, “Federated fraud detection: A real-world cross-silo evaluation,” *IEEE Transactions on Knowledge and Data Engineering*, 2025.
- [16] V. Naresh, N. Kumar, and P. K. Singh, “Federated learning for payment fraud detection: A comprehensive survey,” *ACM Computing Surveys*, 2024.
- [17] Y. A. Farrukh, I. Khan, and M. Z. Baig, “A survey on federated learning for credit card fraud detection: Challenges and opportunities,” *IEEE Access*, vol. 13, 2025.
- [18] V. Shejwalkar, A. Houmansadr, P. Kairouz, and D. Ramage, “FLAME: Robust federated learning via adaptive model aggregation,” in *Proceedings of USENIX Security*, 2023.
- [19] J. Wang, Z. Liu, and Q. Yang, “ShieldFL: Mitigating model poisoning attacks in federated learning,” *IEEE Transactions on Dependable and Secure Computing*, 2024.
- [20] L. Zhang, B. Li, and Y. Wang, “FedDef: Defense against gradient leakage and poisoning in federated learning,” in *Advances in NeurIPS*, 2024.
- [21] M. Fang, X. Cao, J. Jia, and N. Z. Gong, “Local model poisoning attacks to byzantine-robust federated learning,” in *Proceedings of USENIX Security*, 2020, pp. 1605–1622.
- [22] S. Jagielski, A. Oprea, B. Biggio, C. Liu, C. Nita-Rotaru, and B. Li, “Manipulating machine learning: Poisoning attacks and countermeasures for regression learning,” in *Proceedings of IEEE S&P*, 2018, pp. 19–35.
- [23] V. Shejwalkar and A. Houmansadr, “Manipulating the byzantine: Optimizing model poisoning attacks in federated learning,” in *Proceedings of NDSS*, 2021.
- [24] G. Baruch, M. Baruch, and Y. Goldberg, “A little is enough: Circumventing defenses for distributed learning,” in *Advances in NeurIPS*, 2019, pp. 8635–8645.
- [25] C. Xie, K. Huang, P.-Y. Chen, and B. Li, “DBA: Distributed backdoor attacks against federated learning,” in *Proceedings of ICLR*, 2020.
- [26] IEEE Computational Intelligence Society, “IEEE-CIS fraud detection dataset,” 2019, kaggle. Available at <https://kaggle.com/c/ieee-fraud-detection>.
- [27] A. D. Pozzolo, O. Caelen, R. A. Johnson, and G. Bontempi, “Calibrating probability with undersampling for unbalanced classification,” in *Proceedings of IEEE CIDM*, 2015, pp. 159–166.
- [28] K. Pillutla, S. M. Kakade, and Z. Harchaoui, “Robust aggregation for federated learning,” *IEEE Transactions on Signal Processing*, vol. 70, pp. 1142–1154, 2022.
- [29] M. Abadi *et al.*, “Deep learning with differential privacy,” in *Proceedings of ACM CCS*, 2016, pp. 308–318.
- [30] G. W. Stewart, “On the early history of the singular value decomposition,” *SIAM Review*, vol. 35, no. 4, pp. 551–566, 1993.
- [31] Court of Justice of the European Union, “Data protection commissioner v. facebook ireland and maximilian schrems (*Schrems II*),” 2020, case C-311/18.